SFL ULS — Bugs y áreas de mejora

Oct 2, 2026 · Cristian Cubillos

Resumen

La revisión encontró 5 bugs (1 crítico, 1 alto, 2 medios, 1 bajo) y 19 áreas de mejora (8 de seguridad, 8 de código y 3 de experiencia de usuario). El bug crítico impide cambiar la contraseña. El alto impide enviar correos.

- **Alcance:** todo el repositorio PPII-004 / PPII-005 (PHP 8.2 sin framework, PostgreSQL, Apache), revisado para publicarlo en Hostinger.
- **Método:** lectura del código y pruebas de integración en Docker (PHP 8.2 + Apache).

Bugs confirmados

Cinco bugs, ordenados por severidad. BUG-01 se reprodujo en vivo; el resto sale del análisis del código.

ID	Severidad	Bug	Ubicación
BUG-01	Crítica	Cambiar la contraseña termina en `TypeError`: `findById()` no trae la columna `password`. Un usuario con `must_change_password = true` queda sin acceso al panel.	`app/Controllers/PasswordController.php:49`
BUG-02	Alta	`MAIL_DRIVER=smtp` llama a `mail()`. En Linux ignora `SMTP_HOST`, y `SMTP_USER` / `SMTP_PASS` nunca se leen. En Docker los correos no salen.	`app/Services/MailerService.php:188`
BUG-03	Media	PHP y la base calculan la expiración del token con zonas horarias distintas. Con PHP en UTC−3 y la base en UTC, el enlace llega vencido.	`PasswordResetService.php:95`, `PasswordResetRepository.php:48`
BUG-04	Media	Usuarios semilla con contraseñas publicadas en `README.md` y `must_change_password = f`.	`config/schema.sql:610`

ID	Severidad	Bug	Ubicación
BUG-05	Baja	El dump trae datos de prueba: "Test API", "Test Project", usuario `testu`.	`config/schema.sql`

Seguridad

Ocho riesgos, aparte de BUG-04. Los tres primeros permiten evadir el control de abuso o enviar spam sin autenticación.

#	Riesgo	Ubicación	Mejora sugerida
SEC-01	`getClientIp()` toma la primera IP de `X-Forwarded-For`, que el cliente controla. Cambiando esa cabecera se evade el bloqueo por IP del login.	`app/Services/RateLimiterService.php`	Usar `REMOTE_ADDR`, o leer `X-Forwarded-For` solo si viene de un proxy de confianza.
SEC-02	`/api/auth/login` valida el captcha solo si el cliente lo envía o si ya existe uno en sesión. Un script lo omite.	`app/Controllers/AuthController.php`	Exigir captcha siempre, o tras N intentos fallidos.
SEC-03	`POST /api/queries` y `POST /api/credits/contact` no exigen CSRF, captcha ni límite de envíos. El formulario `/contacto` tampoco tiene captcha. Cada envío dispara un correo.	`public/index.php`, `QueryController`, `CreditsApiController`, `ContactoController`	Captcha o honeypot y límite por IP y por correo.
SEC-04	La política de contraseñas es inconsistente: 6 caracteres en `/cambiar-password` y 12 en el resto.	`PasswordController.php:69` frente a `UserService.php:137`	Una sola regla en un solo lugar (12 caracteres).
SEC-05	No hay `Content-Security-Policy`. Se envía `X-XSS-Protection`, cabecera obsoleta.	`app/helpers.php` `sendSecurityHeaders()`, `public/.htaccess`	Agregar CSP; quitar `X-XSS-Protection`.

#	Riesgo	Ubicación	Mejora sugerida
SEC-06	`GET /logout` cierra la sesión. Una imagen en otro sitio puede desloguear al usuario.	`public/index.php`	Cerrar sesión solo por `POST` con CSRF.
SEC-07	`MediaService` crea la carpeta de uploads con permisos `0777`.	`app/Services/MediaService.php:205`	Usar `0755`.
SEC-08	Sin manejador global de excepciones. Si la base cae, `/login` termina en `Uncaught PDOException`: página en blanco, o traza visible si `display_errors` está activo.	`public/index.php`	`set_exception_handler()` con página 500 genérica y registro en log.

Calidad de código y arquitectura

El problema más urgente es CAL-01: si la base de datos cae, el sitio publica datos ficticios y nadie se entera.

#	Hallazgo	Ubicación	Mejora sugerida
CAL-01	Los controladores públicos capturan `\Throwable` sin registrar el error y muestran datos de muestra escritos en el código (noticias, staff, servicios). Una caída de la base pasa inadvertida.	`HomeController`, `NoticiasController`, `StaffWebController`, `ServiciosController`	Registrar con `error_log()`; mostrar los datos de muestra solo en `APP_ENV=development`.
CAL-02	Controladores y rutas duplicados: `NewsController` / `NoticiasController`, `ProjectController` / `ProyectosController`, `ServiceController` / `ServiciosController`, `StaffController` / `StaffWebController`, tres controladores de créditos; `/api/upload` y `/api/media/upload`.	`app/Controllers/`, `public/index.php`	Separar en `Controllers/Web` y `Controllers/Api`; una ruta por acción.
CAL-03	`AdminController` tiene 887 líneas y atiende 7 secciones del panel.	`app/Controllers/AdminController.php`	Un controlador por sección.
CAL-04	`helpers.php` reúne 552 líneas de funciones globales: configuración, conexión con `static`, sesión, middleware y respuestas. Es difícil de probar con mocks.	`app/helpers.php`	Clases pequeñas (`Database`, `Session`, `Response`) inyectadas en los servicios.
CAL-05	El router es un arreglo en `index.php`, recorre todas las rutas dinámicas y no responde 405 cuando el método no coincide.	`public/index.php`	Router dedicado (por ejemplo `nikic/fast-route`).

#	Hallazgo	Ubicación	Mejora sugerida
CAL-06	`MediaService` vuelve a cargar `config/app.php` con `require` en lugar de usar `config()`.	`app/Services/MediaService.php:23`	Usar `config()` o recibir la configuración por constructor.
CAL-07	No hay test que ejecute `PasswordController::submit()` con la contraseña correcta; por eso BUG-01 llegó al repositorio. Varios tests necesitan una base real.	`tests/`	Test de éxito del cambio de contraseña; base de pruebas aislada por test.
CAL-08	El comentario de cabecera de `MailerService` está desactualizado: dice "SMTP NO CONFIGURADO" y describe un envío SMTP que no existe.	`app/Services/MailerService.php:7-29`	Actualizarlo junto con BUG-02.

Datos y experiencia de usuario

Tres puntos visibles para quien usa el sitio; los tres se resuelven antes del lanzamiento sin tocar la arquitectura.

#	Hallazgo	Ubicación	Mejora sugerida
UX-01	Si `TICKET_PLATFORM_URL` está vacío, enviar el formulario de contacto lleva a `about:blank`. El usuario ve una página en blanco y no sabe si su consulta llegó.	`app/Controllers/ContactoController.php:81`	Volver a `/contacto` con un mensaje de confirmación.
UX-02	La marca aparece de tres formas: "SFL ULS Lab", "SFL ULS" y "Software Factory Lab ULS", en títulos de página, correos y `config/app.php`.	Controladores, `MailerService`, `CreditsService`, `layout/header.php`	Definir el nombre oficial y tomarlo de `config('app_name')`.
UX-03	Los datos semilla traen contenido ficticio que se publica tal cual: teléfono `+56912345678`, dirección "Av. Raúl Valenzuela 123", enlaces de GitHub inexistentes y staff de ejemplo.	`config/schema.sql`	Reemplazar desde el panel antes del lanzamiento, o sembrar campos vacíos.

Cambio de marca: Tech Hub a SFL ULS

El repositorio ya no menciona "Tech Hub": el cambio se aplicó en 33 archivos (código, vistas, SQL, tests, CI, Docker y documentación).

Antes	Ahora	Dónde aparece
`Tech Hub ULS`, `TechHub ULS`, `Tech Hub`, `TechHub`	`SFL ULS`	Títulos, correos, contenido semilla, README

Antes	Ahora	Dónde aparece
`@techhub.cl`	`@sfluls.cl`	Usuarios semilla, pie de página, tests
`techhub.uls.cl`	`sfl.uls.cl`	`SMTP_FROM` de ejemplo, comentarios
`techhub`	`sfluls`	Base y usuario por defecto, contenedores Docker, CI, clave de `localStorage`
`tech-hub-uls/proyecto`	`sfl-uls/proyecto`	`composer.json`

Qué debe hacer cada integrante:

- **Credenciales de prueba:** ahora son `admin@sfluls.cl`, `editor@sfluls.cl` y `redactor@sfluls.cl`, con las mismas contraseñas.
- **Docker local:** los contenedores se llaman `sfluls_web_dev` y `sfluls_postgres_dev`. Detener y borrar los antiguos `techhub_*` antes de levantar el entorno.
- **Bases ya cargadas** (local o Hostinger): conservan los correos antiguos. Ejecutar una vez:

```
UPDATE app_user SET email = REPLACE(email, '@techhub.cl', '@sfluls.cl');
UPDATE footer_info SET email = REPLACE(email, '@techhub.cl', '@sfluls.cl');
UPDATE news SET title = REPLACE(title, 'Tech Hub ULS', 'SFL ULS'), content =
REPLACE(content, 'Tech Hub ULS', 'SFL ULS');
UPDATE staff_member SET description = REPLACE(description, 'Tech Hub ULS',
'SFL ULS');
```

- **Aviso legal:** cambió la clave de `localStorage`, así que cada visitante verá el aviso una vez más.
- **Nombre del sitio:** queda pendiente unificar "SFL ULS Lab" y "SFL ULS" (UX-02).

Plan de acción

Tres etapas. La etapa 1 bloquea el lanzamiento; las otras dos pueden ir en sprints siguientes. El área entre corchetes es una sugerencia.

Etapa 1 — antes del lanzamiento

- [ ] BUG-01: cambio de contraseña [Backend]
- [ ] BUG-04: sembrar usuarios con cambio obligatorio y retirar cuentas de ejemplo [Backend]

- [ ] BUG-02: envío SMTP autenticado [Backend]
- [ ] BUG-03: zona horaria única [Backend]
- [ ] SEC-01, SEC-02 y SEC-03: IP real, captcha obligatorio y límite en formularios públicos [Backend]
- [ ] UX-03: reemplazar datos ficticios desde el panel [Contenido]
- [ ] Ejecutar el SQL de cambio de marca en las bases ya cargadas [Backend]

Etapa 2 — siguiente sprint

- [ ] CAL-01: registrar errores y limitar los datos de muestra a desarrollo [Backend]
- [ ] CAL-07: test del cambio de contraseña y base de pruebas aislada [QA]
- [ ] SEC-04 a SEC-08 [Backend]
- [ ] UX-01 y UX-02: confirmación de contacto y nombre único del sitio [Frontend]
- [ ] BUG-05: separar `schema.sql` y `seed.sql` [Backend]

Etapa 3 — deuda técnica

- [ ] CAL-02 a CAL-06: separar controladores Web y API, dividir `AdminController`, sacar `helpers.php` a clases, router dedicado [Backend]
- [ ] CAL-08: actualizar el comentario de `MailerService` [Backend]